

QA LEADERSHIP ACADEMY

AI Governance Checklist

The controls that must be in place before AI is used routinely in your QA function.

Purpose

This checklist defines the minimum governance that should be in place before AI becomes a routine part of QA work. It covers approved tools, data and PII handling, IP and source-code protection, quality control of AI output, human-in-the-loop accountability, skills protection and vendor considerations. It is a practical control set, not a legal document, and it defers to your organisation's own data-protection and security policies wherever they apply.

A CHECKLIST, NOT A LEGAL OPINION

Ticking these boxes reduces risk and creates a clear record; it does not constitute legal or compliance sign-off. Route anything touching personal data, security or contracts through the people who own those policies.

When to use it

- When moving from informal, ad-hoc AI use to sanctioned, routine use.
- As the standing gate any new AI use case must pass before adoption.
- In a periodic review, to confirm controls are still met as usage grows.

Instructions

1. Work through each control and mark it in place, partial or missing.
2. For anything partial or missing, name an owner and a target date.
3. Treat the human-in-the-loop and data/IP controls as mandatory gates — do not sanction routine use until they are in place.
4. Defer every data-protection, security and contractual question to the relevant policy owner; record who that is.
5. Re-run the checklist periodically and whenever a new tool or use case is introduced.

The checklist

- Approved-tools list exists; staff know which AI tools are sanctioned and which are not.

- A clear rule that no customer data or PII is entered into non-approved tools; aligned with the data-protection policy.
- A clear rule that no proprietary source code or confidential material is pasted into public tools; aligned with the security policy.
- Every AI-assisted output (test, code, report) is reviewed by a competent human before it is relied upon.
- A named human is accountable for each AI-assisted deliverable; accountability never rests with the tool.
- AI-generated tests are checked for real assertions, not tautologies that always pass.
- Guidance exists on when NOT to use AI (e.g. safety-critical judgement, anything with unmanaged PII).
- Skills protection: juniors still learn the underlying reasoning; AI augments rather than replaces development.
- Vendor considerations reviewed: data-handling terms, portability, avoidance of premature lock-in.
- A lightweight record of AI use and decisions is kept, proportionate to risk.
- Staff are told how to raise a concern about an AI output or use.
- The policy is reviewed on a set cadence and when tools or regulations change.

Worked example

Applied to Northstar's current situation — a couple of testers already pasting code and tickets into public AI tools, with no policy at all:

Control	Status	Action / owner
Approved-tools list	Missing	QA lead to propose a shortlist with security; interim rule: public tools for non-sensitive text only
No PII in non-approved tools	Missing	Immediate written rule; defer specifics to the data-protection owner
No proprietary source in public tools	Missing	Immediate written rule; this is today's biggest live exposure
Human review of AI output	Partial	Informally happening; make it an explicit expectation
Named accountability	Missing	Author of the deliverable remains accountable — state it
Tests checked for real assertions	Partial	Add to peer-review guidance
Guidance on when not to use AI	Missing	Draft a short one-pager
Skills protection	Not considered	Set expectation that juniors reason first, then check with AI
Vendor / data-handling review	Missing	Review terms before any tool is approved

The reading is stark but constructive: Northstar has a live governance gap, and the two most urgent controls are "no proprietary source into public tools" and "no PII into non-approved tools". A pragmatic QA leader issues those two rules in writing this week, channels existing use into a safe lane, and builds the fuller policy over the following weeks with security and the data-protection owner — rather than pretending the informal use is not happening.

Blank reusable version

Control	Status (in place / partial / missing)	Owner	Target date
Approved-tools list			
No PII in non-approved tools			
No proprietary source in public tools			
Human review of AI output			
Named accountability			
Tests checked for real assertions			
Guidance on when not to use AI			
Skills protection			
Vendor / data-handling review			
Record-keeping proportionate to risk			
Route to raise concerns			
Review cadence set			

Common mistakes

COMMON MISTAKES

Banning AI outright so use simply goes underground; writing an aspirational policy nobody can follow; forgetting the human-in-the-loop control, which is the whole point; giving legal or privacy rulings instead of deferring to the policy owners; and treating the checklist as one-off paperwork rather than a control you re-run as usage grows.

How to interpret the results

- Any missing mandatory gate (data, IP, human-in-the-loop) means routine use is not yet safe to sanction, whatever else is green.
- A wall of "missing", as at Northstar, is a prompt to issue the two or three highest-impact rules now, not to wait for a perfect policy.
- "Partial" on human review usually means it happens informally — make it explicit before you rely on it.
- Governance maturity is a trend: fewer missing controls each review is the signal, not a single perfect snapshot.

INSIDE STLC PRO TIP

Do not wait for a perfect AI policy before acting. Two clear rules in writing this week — no source code and no customer data in public tools — plus a named accountable human, cover the majority of the real exposure. Governance that ships beats a comprehensive policy that never does.